



4NESE - Sécurisation des réseaux

Audit et sécurisation d'une infrastructure réseau d'entreprise

Aristide Wafo - Antoine Douay
20/05/2026

Table des matières

Introduction	3
1 : Audit et analyse de l'infrastructure existante	4
1.1 Cartographie du réseau actuel	4
1.2 Analyse du trafic réseau (Wireshark)	5
A. Utilisation de protocoles non sécurisés et compromission d'identifiants	5
B. Détection d'un scan de ports suspect	6
C. Indicateurs d'usurpation d'identité (ARP Spoofing).....	6
1.3 Scan de vulnérabilités (Nmap)	7
1.4 Matrice des vulnérabilités	10
1.5 Scénarios d'attaque.....	10
2 : Stratégie de remédiation et nouvelle architecture	12
2.1 Plan de remédiation.....	12
2.2 Nouveau plan d'adressage et segmentation	14
A. Plan d'adressage sécurisé	14
B. Matrice des flux autorisés (Politique de filtrage)	15
2.3 Schéma de l'infrastructure sécurisée	15
3 : Implémentations techniques de sécurité	16
3.1 Sécurisation du périmètre et filtrage (Firewall)	16
3.2 Détection d'intrusion (IDS) avec Suricata	18
3.3 Sécurisation des accès physiques et sans-fil.....	19
A. Chiffrement de l'administration (SSH) :	19
B. Contrôle d'accès filaire (802.1X)	19
C. Durcissement de la sécurité WiFi.....	19
Conclusion	20

Introduction

Le présent rapport s'inscrit dans le cadre du projet d'audit et de sécurisation des réseaux. Nous avons été missionnés en tant que consultants en cybersécurité pour intervenir auprès de NetSecure Corp, une PME comptant 200 employés. Cette entreprise dispose d'une infrastructure réseau classique répartie sur trois sites distincts : un siège principal ainsi que deux agences distantes (Agence A et Agence B) reliées par des liaisons WAN.

Actuellement, l'architecture informatique de NetSecure Corp souffre d'une conception obsolète et présente de multiples failles de sécurité critiques. Au sein du siège, le réseau est totalement "plat", regroupant l'ensemble des équipements sur un unique sous-réseau (10.0.0.0/16) sans aucune segmentation logique (VLAN). Cette absence de cloisonnement expose directement le réseau interne, d'autant plus que le serveur Web public n'est pas isolé dans une zone démilitarisée (DMZ).

Par ailleurs, l'audit initial a mis en évidence des pratiques d'administration à haut risque, telles que l'utilisation du protocole Telnet transmettant les identifiants en clair (avec des mots de passe par défaut faibles comme "cisco/cisco"), l'absence d'un pare-feu, une sécurité WiFi obsolète et l'absence totale de système de détection d'intrusion (IDS).

Face à ces constats, notre mission s'articule autour de deux objectifs majeurs :

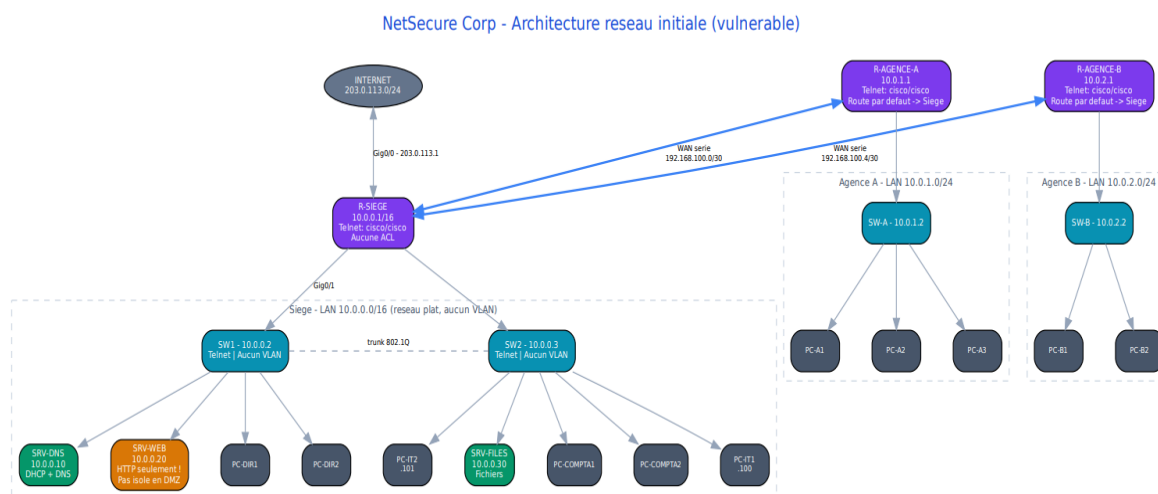
1. Auditer l'infrastructure existante : Analyser le trafic en temps réel, cartographier le réseau, et scanner les vulnérabilités pour démontrer les risques d'exploitation.
2. Proposer et implémenter un plan de sécurisation complet : Remédier aux failles identifiées en repensant le plan d'adressage via une segmentation stricte, en déployant des règles de filtrage, en remplaçant les protocoles vulnérables par des standards chiffrés (SSH, WPA2-Entreprise, 802.1X), et en intégrant une sonde de détection d'intrusion.

Ce rapport détaillera les étapes de notre diagnostic, les preuves des vulnérabilités identifiées, ainsi que la nouvelle architecture sécurisée déployée pour protéger durablement le système d'information de NetSecure Corp.

1 : Audit et analyse de l'infrastructure existante

1.1 Cartographie du réseau actuel

L'infrastructure initiale de NetSecure Corp est répartie sur trois sites physiques : un siège principal et deux agences distantes. L'audit de l'architecture réseau met en évidence une conception obsolète et de multiples faiblesses structurelles qui exposent l'entreprise à des risques majeurs.



Le réseau local (LAN) du siège repose sur une architecture totalement "plate" utilisant un sous-réseau très large (10.0.0.0/16). Actuellement, les deux switches d'accès de couche 2 (SW1 et SW2) ne disposent d'aucun réseau local virtuel (VLAN) configuré. Par conséquent, l'ensemble des équipements du siège qu'il s'agisse des serveurs d'infrastructure, des postes de la direction (PC-DIR), de la comptabilité (PC-COMPTA) ou des administrateurs IT (PC-IT) partagent le même domaine de diffusion. Un réseau plat est un environnement hautement vulnérable : l'absence de segmentation logique permettrait une attaque (comme un ransomware) où un attaquant ayant un accès initial pourrait se propager librement par mouvement latéral, sans aucune restriction interne.

Le serveur Web public de l'entreprise (SRV-WEB - 10.0.0.20) est placé directement au cœur du réseau local. Il n'est pas isolé au sein d'une zone démilitarisée (DMZ). Ainsi, si un attaquant parvient à compromettre ce serveur, il obtiendra un accès direct aux serveurs critiques adjacents, tels que le serveur de fichiers (SRV-FILES - 10.0.0.30) ou le contrôleur de domaine (SRV-DNS - 10.0.0.10).

Les réseaux des agences A (10.0.1.0/24) et B (10.0.2.0/24) sont reliés au routeur principal du siège (R-SIEGE) par le biais de liaisons WAN série (respectivement 192.168.100.0/30 et 192.168.100.4/30). Le trafic issu de ces agences est redirigé vers le siège via une route par

défaut. Le trafic transitant sur ces liaisons inter-sites n'est actuellement pas encapsulé dans un tunnel sécurisé (VPN).

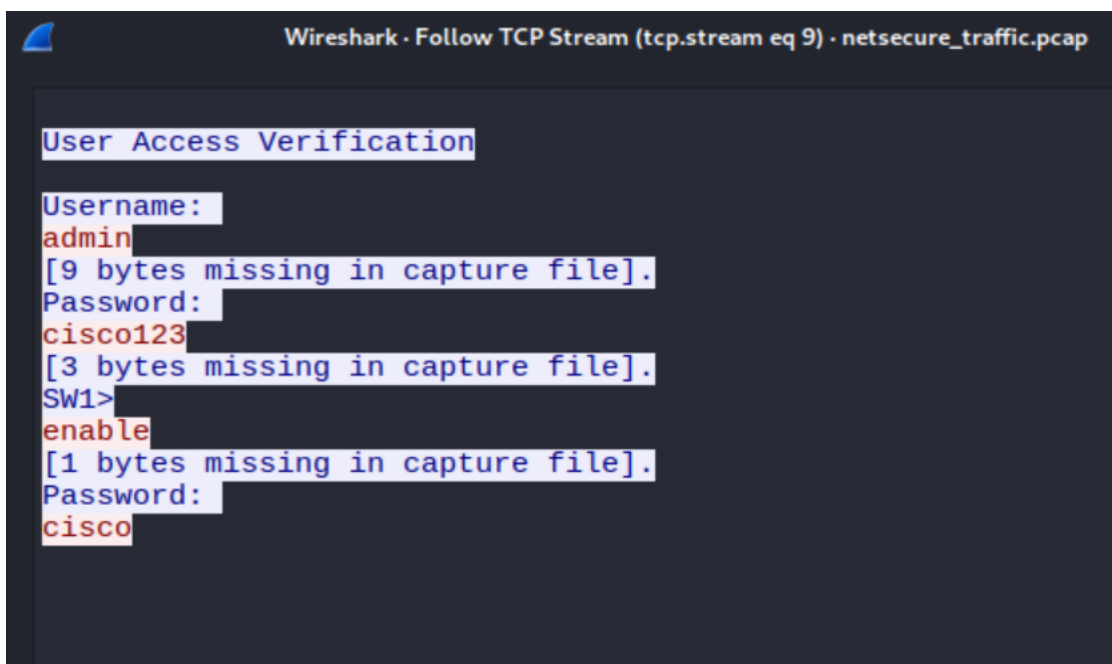
Le routeur périmétrique R-SIEGE, qui relie l'entreprise à Internet (203.0.113.0/24), ne dispose d'aucune liste de contrôle d'accès (ACL) ou politique de filtrage restrictive. De plus, l'administration de ce routeur, ainsi que de tous les autres routeurs et switchs de l'infrastructure (SW1, SW2, R-AGENCE-A, etc.), s'effectue via Telnet. Ce protocole obsolète transmet les données en clair sur le réseau. Pire encore, les identifiants d'accès configurés sur ces équipements réseau sont les valeurs par défaut de l'éditeur (cisco/cisco), offrant une cible triviale pour tout attaquant réalisant une écoute passive du réseau.

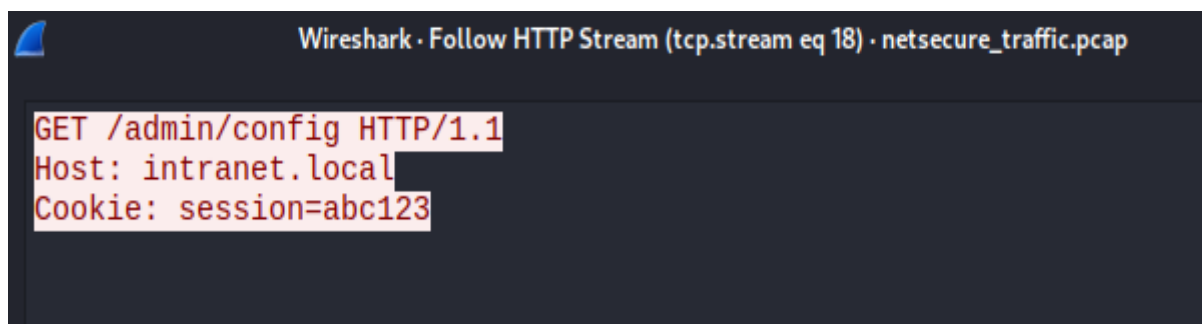
1.2 Analyse du trafic réseau (Wireshark)

L'analyse de la capture réseau `netsecure_traffic.pcap` nous a permis d'observer le trafic réel circulant sur l'infrastructure de NetSecure Corp et de confirmer l'exploitation active de plusieurs vulnérabilités critiques.

A. Utilisation de protocoles non sécurisés et compromission d'identifiants

L'examen des flux a mis en évidence l'utilisation de protocoles obsolètes qui transmettent les données en clair sur le réseau. En appliquant le filtre `tcp.port == 23` dans Wireshark et en utilisant la fonctionnalité d'analyse des flux TCP, nous avons pu isoler les sessions d'administration des équipements réseau. Cette manipulation nous a permis de lire directement et en clair les identifiants de connexion : les administrateurs utilisent les valeurs par défaut cisco pour le nom d'utilisateur et cisco pour le mot de passe. En parallèle, du trafic HTTP non chiffré a été intercepté, exposant potentiellement des cookies de session et des données sensibles transitant vers le serveur web.





B. Détection d'un scan de ports suspect

L'analyse des paquets a également révélé une phase de reconnaissance active sur le réseau. Nous avons identifié un balayage de ports (de type scan Nmap) ciblant l'infrastructure. Ce type d'activité se caractérise généralement par l'envoi rapide et massif de requêtes vers de multiples ports cibles, dans le but d'identifier les services ouverts sans finaliser la connexion. La présence de ce scan confirme qu'une machine interne (potentiellement compromise) cartographie les services exposés de l'entreprise pour identifier des cibles potentielles.

2 0.011515	10.0.0.200	10.0.0.20	TCP	54 53049 → 8080 [SYN] Seq=0 Win=8192 Len=0
4 0.010765	10.0.0.200	10.0.0.20	TCP	54 65309 → 443 [SYN] Seq=0 Win=8192 Len=0
5 0.010327	10.0.0.200	10.0.0.20	TCP	54 45816 → 80 [SYN] Seq=0 Win=8192 Len=0
11 0.011248	10.0.0.200	10.0.0.20	TCP	54 59060 → 3389 [SYN] Seq=0 Win=8192 Len=0
17 0.009857	10.0.0.200	10.0.0.20	TCP	54 41483 → 22 [SYN] Seq=0 Win=8192 Len=0
19 0.009721	10.0.0.200	10.0.0.20	TCP	54 61791 → 21 [SYN] Seq=0 Win=8192 Len=0
21 0.009967	10.0.0.200	10.0.0.20	TCP	54 57546 → 23 [SYN] Seq=0 Win=8192 Len=0
26 -0.002929	10.0.0.100	10.0.0.2	TCP	54 49152 → 23 [SYN] Seq=0 Win=8192 Len=0
38 0.010655	10.0.0.200	10.0.0.20	TCP	54 43451 → 139 [SYN] Seq=0 Win=8192 Len=0
43 0.010907	10.0.0.200	10.0.0.20	TCP	54 57052 → 445 [SYN] Seq=0 Win=8192 Len=0
45 0.010543	10.0.0.200	10.0.0.20	TCP	54 47866 → 135 [SYN] Seq=0 Win=8192 Len=0
50 0.010434	10.0.0.200	10.0.0.20	TCP	54 63115 → 110 [SYN] Seq=0 Win=8192 Len=0
52 0.011139	10.0.0.200	10.0.0.20	TCP	54 51556 → 3306 [SYN] Seq=0 Win=8192 Len=0
54 0.011026	10.0.0.200	10.0.0.20	TCP	54 43496 → 993 [SYN] Seq=0 Win=8192 Len=0
69 0.010199	10.0.0.200	10.0.0.20	TCP	54 50800 → 53 [SYN] Seq=0 Win=8192 Len=0
73 0.010075	10.0.0.200	10.0.0.20	TCP	54 48195 → 25 [SYN] Seq=0 Win=8192 Len=0

C. Indicateurs d'usurpation d'identité (ARP Spoofing)

Enfin, l'étude des trames de couche 2 a révélé une attaque de type "Man-in-the-Middle" via une usurpation ARP, communément appelée *ARP Spoofing*. Le protocole ARP ne disposant d'aucun mécanisme d'authentification natif, nous avons pu observer dans la capture Wireshark qu'une seule et même adresse MAC (celle de la machine attaquante) était associée de manière illégitime à plusieurs adresses IP différentes. L'absence totale de mesures de sécurité sur les switches, telles que le *Dynamic ARP Inspection* (DAI), a permis à l'attaquant de polluer le cache ARP des autres machines pour intercepter et relayer silencieusement leur trafic.

```
▼ Address Resolution Protocol (request)
  Hardware type: Ethernet (1)
  Protocol type: IPv4 (0x0800)
  Hardware size: 6
  Protocol size: 4
  Opcode: request (1)
  Sender MAC address: Microsoft_d9:26:b5 (00:15:5d:d9:26:b5)
  Sender IP address: 10.0.0.141
  Target MAC address: 00:00:00_00:00:00 (00:00:00:00:00:00)
  Target IP address: 10.0.0.234
```

```
▼ Address Resolution Protocol (request)
  Hardware type: Ethernet (1)
  Protocol type: IPv4 (0x0800)
  Hardware size: 6
  Protocol size: 4
  Opcode: request (1)
  Sender MAC address: Microsoft_d9:26:b5 (00:15:5d:d9:26:b5)
  Sender IP address: 10.0.0.134
  Target MAC address: 00:00:00_00:00:00 (00:00:00:00:00:00)
  Target IP address: 10.0.0.179
```

```
▼ Address Resolution Protocol (request)
  Hardware type: Ethernet (1)
  Protocol type: IPv4 (0x0800)
  Hardware size: 6
  Protocol size: 4
  Opcode: request (1)
  Sender MAC address: Microsoft_d9:26:b5 (00:15:5d:d9:26:b5)
  Sender IP address: 10.0.0.243
  Target MAC address: 00:00:00_00:00:00 (00:00:00:00:00:00)
  Target IP address: 10.0.0.183
```

1.3 Scan de vulnérabilités (Nmap)

Afin d'évaluer concrètement la surface d'attaque de NetSecure Corp, nous avons réalisé un scan actif de l'infrastructure à l'aide de l'outil Nmap. Pour cette simulation technique, nous avons ciblé les services d'infrastructure vitaux et les serveurs critiques identifiés lors de la phase de découverte.

Nous avons privilégié un balayage de type "SYN scan" (option -sS), qui est la méthode par défaut de Nmap (nécessitant des privilèges d'administration) permettant un scan rapide et relativement discret en n'achevant pas les connexions TCP. Pour obtenir un maximum

d'informations, nous avons combiné ce balayage avec la détection des versions logicielles (option -sV) et la détection du système d'exploitation (option -O).

Les commandes types utilisées pour auditer le réseau ciblé (10.0.0.0/16) étaient de la forme : `nmap -sS -sV -O -p- [IP_Cible]`.

Le scan des adresses IP correspondant aux équipements d'infrastructure (notamment 10.0.0.1 pour le routeur R-SIEGE, et 10.0.0.2 / 10.0.0.3 pour les switchs SW1 et SW2) a confirmé l'ouverture du port TCP 23. La détection de service a corroboré qu'il s'agit bien du protocole d'administration Telnet. Ce résultat critique valide notre analyse de trafic (Wireshark) : les équipements sont administrables via un protocole en clair, exposant directement l'infrastructure à une compromission totale en cas d'écoute réseau.

```
(wafo@kali)-[~]
$ nmap -sS 10.0.0.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-17 23:23 +0200
Nmap scan report for 10.0.0.1
Host is up (0.000010s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
23/tcp    open  telnet
MAC Address: CA:7A:E9:DB:D5:87 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.76 seconds

(wafo@kali)-[~]
$ nmap -sS 10.0.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-17 23:23 +0200
Nmap scan report for 10.0.0.2
Host is up (0.000013s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
23/tcp    open  telnet
MAC Address: FA:E7:AD:11:65:00 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.75 seconds
```

L'analyse s'est ensuite concentrée sur les serveurs de l'entreprise :

- SRV-WEB (10.0.0.20) : Le scan révèle que seul le port TCP 80 (HTTP) est ouvert au public. Le port 443 (HTTPS), standard actuel pour les communications web sécurisées, est fermé. Le scan confirme également, au vu de l'adressage IP local, que ce serveur n'est isolé par aucune zone démilitarisée (DMZ).


```
(wafo@kali)-[~]
$ nmap -sS 10.0.0.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-17 23:31 +0200
Nmap scan report for 10.0.0.20
Host is up (0.0000090s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 4E:47:72:AA:18:39 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.74 seconds
```

- SRV-DNS (10.0.0.10) et SRV-FILES (10.0.0.30) : Nmap identifie l'ouverture des ports UDP/TCP 53 (DNS) et très certainement l'ouverture de ports liés au partage de fichiers (comme SMB sur le port 445 pour le SRV-FILES). Étant situés sur le même réseau plat (10.0.0.0/16) que les postes utilisateurs et le serveur web, ces services critiques sont directement exposés au moindre mouvement latéral.

```
(wafo@kali)-[~]
$ sudo nmap -sU -p 53 10.0.0.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-19 16:11 +0200
Nmap scan report for 10.0.0.10
Host is up (0.000050s latency).

PORT      STATE      SERVICE
53/udp    open|filtered domain
MAC Address: BE:E6:BF:C7:83:AB (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.93 seconds
```

En conclusion, ce scan actif démontre que l'architecture actuelle viole les principes de base de la sécurité (défense en profondeur et moindre privilège), laissant de multiples portes d'entrée exploitables par un attaquant interne ou ayant compromis le serveur web.

1.4 Matrice des vulnérabilités

L'audit de l'architecture et l'analyse du trafic réseau de NetSecure Corp ont permis d'identifier de multiples faiblesses, tant au niveau de la conception structurelle (réseau plat, absence de DMZ) que de la configuration des équipements (protocoles en clair, absence de filtrage).

Le tableau ci-dessous synthétise et classe ces vulnérabilités selon leur niveau de criticité, tout en évaluant leur impact potentiel sur le système d'information et en proposant des recommandations de remédiation

Vulnérabilité identifiée	Niveau de Criticité	Impact potentiel	Recommandation de remédiation
Administration réseau en clair (Telnet)	Critique	Les identifiants transitent en clair sur le réseau, permettant à un attaquant réalisant une simple écoute de prendre le contrôle total des routeurs et switches	Remplacer immédiatement Telnet par SSH et imposer une politique de mots de passe robustes
Réseau plat (10.0.0.0/16) et absence de DMZ	Critique	Le serveur Web public (SRV-WEB) est hébergé directement sur le réseau local interne. En cas de compromission, l'attaquant a un accès direct aux postes de travail et serveurs critiques (SRV-FILES, SRV-DNS) sans aucune restriction	Déployer un plan d'adressage sécurisé avec des VLANs (Admin, Employés, Serveurs) et isoler le serveur public dans une DMZ
Absence de protection de Couche 2 (Switches)	Élevée	L'absence de DHCP Snooping et de Port Security permet à un attaquant de polluer le cache des machines pour intercepter les flux (attaque Man-in-the-Middle via ARP Spoofing)	Activer les fonctionnalités DHCP Snooping, Dynamic ARP Inspection (DAI) et le Port Security sur tous les switches d'accès
Règles de Pare-feu permissives et absence d'IDS	Élevée	Le routeur périmétrique ne filtre pas correctement le trafic entrant et aucun système ne détecte les comportements malveillants, ce qui laisse passer des scans de ports et des attaques sans générer d'alerte	Mettre en place un script Firewall (iptables/nftables) avec une politique "Default Deny" et déployer une sonde IDS (Suricata) avec des règles adaptées
Sécurité WiFi obsolète	Moyenne	Le réseau sans-fil utilise le standard WPA2-PSK avec une clé partagée faible, ce qui rend le réseau vulnérable aux attaques par force brute	Migrer le réseau sans fil vers une authentification WPA2-Enterprise (802.1X / RADIUS)
Trafic Web non chiffré	Moyenne	Le serveur Web expose uniquement le port HTTP (80), ce qui implique que les données et les cookies transitent en clair et peuvent être interceptés	Implémenter des certificats de sécurité pour forcer les communications en HTTPS (TLS 1.3)

1.5 Scénarios d'attaque

Les vulnérabilités identifiées précédemment, lorsqu'elles sont combinées, offrent à un attaquant plusieurs chemins pour compromettre totalement l'infrastructure de NetSecure Corp. Afin de démontrer l'urgence d'une remédiation, nous avons modélisé deux scénarios d'attaque exploitant l'architecture actuelle.

Scénario 1 : Interception d'identifiants et compromission du serveur Web

Ce scénario démontre comment un attaquant, disposant d'un accès physique au réseau local du siège (par exemple via une prise murale non sécurisée par le standard 802.1X), peut prendre le contrôle du trafic et accéder aux serveurs critiques.

Étape 1 : Reconnaissance passive et Sniffing

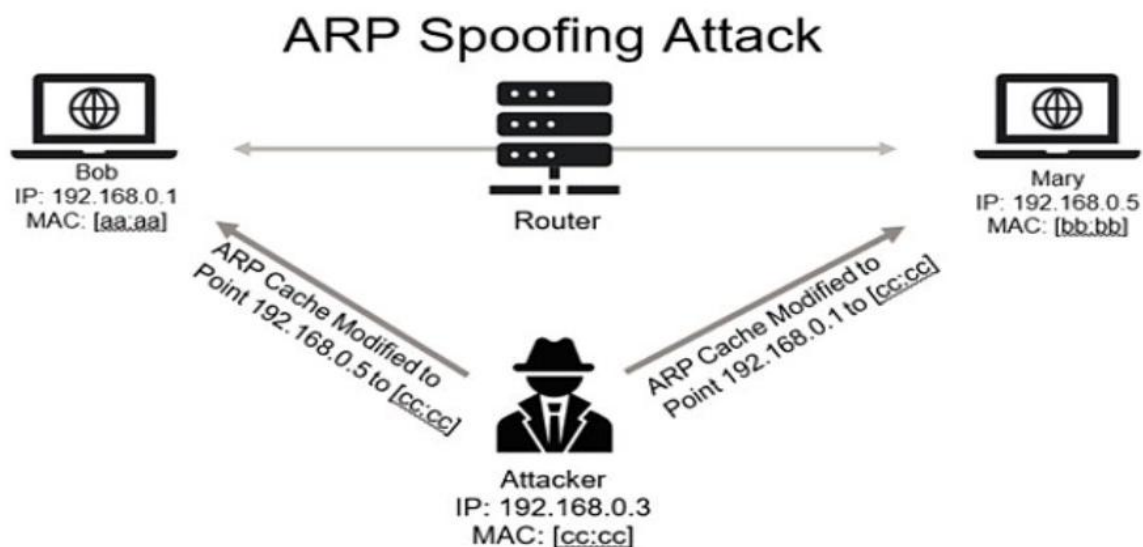
L'attaquant connecte sa machine au réseau plat. Puisque le réseau ne dispose d'aucune segmentation (VLAN), il se trouve dans le même domaine de diffusion que les serveurs et les administrateurs. En écoutant passivement le trafic (sniffing), il intercepte une session d'administration Telnet dirigée vers le routeur central ou un switch. Le protocole Telnet ne chiffrant pas les échanges, l'attaquant récupère en clair les identifiants.

Étape 2 : Attaque Man-in-the-Middle (ARP Spoofing)

L'absence de mesures de protection de Couche 2, telles que le *Dynamic ARP Inspection* (DAI), permet à l'attaquant de lancer une attaque d'usurpation ARP (ARP Spoofing) à l'aide d'outils comme *bettercap* ou *arp spoof*. Il inonde le réseau de fausses réponses ARP, associant sa propre adresse MAC à l'adresse IP de la passerelle (10.0.0.1). Les ordinateurs des employés mettent à jour leur cache ARP et envoient désormais tout leur trafic à l'attaquant.

Étape 3 : Accès au serveur web et exfiltration

Une fois en position d'interception (Man-in-the-Middle), l'attaquant analyse les flux redirigés vers sa machine. Le serveur Web (SRV-WEB - 10.0.0.20) exposant ses services uniquement en HTTP (port 80 en clair), l'attaquant peut facilement intercepter les requêtes des utilisateurs, voler des cookies de session ou exfiltrer des données sensibles transitant vers cette application, sans alerter les utilisateurs.



Schema explicatif - Source : <https://www.riskinsight-wavestone.com/>

Scénario 2 : Mouvement latéral et propagation d'un Ransomware

Ce second scénario illustre le danger extrême du réseau "plat".

Étape 1 : Accès initial via un poste utilisateur

Un employé du service comptabilité (PC-COMPTA1) ouvre une pièce jointe malveillante reçue par email (Phishing). Son poste de travail est immédiatement infecté par un malware de type ransomware.

Étape 2 : Découverte active du réseau

Le malware lance un scan automatisé (similaire à Nmap) pour découvrir les autres machines actives sur le sous-réseau local.

Étape 3 : Mouvement latéral libre

Étant donné que PC-COMPTA1 se trouve sur le même sous-réseau 10.0.0.0/16 que l'intégralité de l'entreprise (y compris la direction et les serveurs critiques) et qu'aucun pare-feu interne ne filtre les flux, le ransomware se propage instantanément. En quelques minutes, il atteint le serveur de fichiers (SRV-FILES - 10.0.0.30) et le contrôleur de domaine (SRV-DNS - 10.0.0.10), chiffrant ainsi l'intégralité des données vitales de l'entreprise. Cette propagation aurait été bloquée si les serveurs avaient été isolés dans des VLANs distincts avec un filtrage strict

2 : Stratégie de remédiation et nouvelle architecture

L'audit détaillé de la phase 1 a mis en évidence un niveau de vulnérabilité critique pour l'infrastructure de NetSecure Corp. Pour pallier ces failles et empêcher tout mouvement latéral ou compromission du système d'information, nous avons élaboré une stratégie de remédiation complète s'appuyant sur les principes de défense en profondeur et du moindre privilège.

2.1 Plan de remédiation

L'audit détaillé de la Phase 1 a mis en évidence un niveau de vulnérabilité critique pour l'infrastructure de NetSecure Corp. Pour pallier ces failles et empêcher tout mouvement latéral ou compromission du système d'information, nous avons élaboré une stratégie de remédiation complète s'appuyant sur les principes de défense en profondeur et du moindre privilège. Avant de procéder aux modifications techniques, nous avons hiérarchisé les actions correctives à mener sous forme d'un plan d'action sur 15 jours. Les tâches ont été priorisées afin de neutraliser immédiatement les failles les plus critiques avant de déployer les sécurités structurelles et de détection.

Désactivation de Telnet et passage à SSH (Jour 1) :

La première urgence absolue consiste à stopper la fuite des identifiants en clair sur le réseau. Il faut un remplacement immédiat du protocole d'administration Telnet par un canal chiffré (SSH) sur l'ensemble des routeurs et switchs de l'infrastructure. Cette action, d'une criticité maximale mais d'une complexité faible, permettra de sécuriser les accès administratifs dès le premier jour.

Création de VLANs et d'une DMZ (Jours 2 à 4) :

Pour contrer le risque majeur de mouvement latéral inhérent au réseau plat actuel (10.0.0.0/16), il faut procéder à la refonte du plan d'adressage. Cette tâche, de criticité maximale et de complexité moyenne, nécessitera trois jours de travail. Elle aboutira à la création de VLANs dédiés (Admin, Employés, Serveurs, WiFi-Invités) et à l'isolation du serveur web public au sein d'une zone démilitarisée (DMZ).

Mise en place du Pare-feu et filtrage (Jours 5 à 7) :

Une fois la segmentation logique établie, l'équipe Sécurité déploiera un script de règles *iptables/nftables* sur le routeur de bordure (R-SIEGE). D'une complexité moyenne mais d'une priorité élevée, cette étape vise à implémenter le principe du "Default Deny" (tout bloquer par défaut). Le pare-feu aura pour rôle de filtrer rigoureusement les flux inter-VLANs et de sécuriser le périmètre face à Internet.

Sécurisation de la Couche 2 sur les Switchs (Jours 8 à 9) :

Afin d'empêcher les attaques de type "Man-in-the-Middle" (comme l'ARP spoofing observé lors de l'audit). On activera les protections de couche 2. Cette tâche de priorité élevée consistera à configurer le Port Security, le DHCP Snooping et le Dynamic ARP Inspection (DAI) sur tous les switchs d'accès.

Déploiement de l'IDS Suricata (Jours 10 à 12) :

Pour assurer une visibilité continue et détecter les futures tentatives d'intrusion, l'équipe SOC installera une sonde NIDS (Suricata) au cœur du réseau. Cette implémentation représente une complexité et une priorité hautes. Elle nécessitera la rédaction et l'intégration de règles spécifiques (détection de scans Nmap, protocoles en clair, trafic suspect) pour s'adapter précisément à l'environnement de NetSecure Corp.

Sécurisation des accès filaires et WiFi (Jours 13 à 15) :

La dernière étape consistera à durcir les accès physiques et sans-fil à l'entreprise. On déploiera un serveur RADIUS pour obliger l'authentification filaire via le standard 802.1X sur les ports des switchs. En parallèle, la sécurité obsolète du réseau sans-fil sera migrée vers les standards WPA2-Enterprise afin d'empêcher les attaques par force brute sur les clés pré-partagées.

2.2 Nouveau plan d'adressage et segmentation

L'audit initial a démontré que l'utilisation d'un réseau "plat" unique (10.0.0.0/16) permettait une propagation sans contrainte des attaques. Afin d'appliquer le principe de défense en profondeur, nous avons repensé intégralement le plan d'adressage de NetSecure Corp.

L'infrastructure du siège repose désormais sur une segmentation stricte de couche 2 (VLANs). Pour assurer le routage inter-VLANs, le routeur principal R-SIEGE est configuré selon le modèle "Router-on-a-stick" : une seule interface physique (Gig0/1) est subdivisée en sous-interfaces virtuelles gérant chacune un VLAN, le trafic étant encapsulé via le protocole de tagging 802.1Q. Conformément aux bonnes pratiques de sécurité, le VLAN 1 par défaut n'est plus utilisé pour le trafic utilisateur.

A. Plan d'adressage sécurisé

L'espace d'adressage a été découpé en sous-réseaux plus restreints (/24), limitant ainsi les domaines de diffusion (broadcast) et facilitant l'application de règles de filtrage :

VLAN 10 (Administration) :

Sous-réseau : 10.0.10.0/24 (Passerelle : 10.0.10.1)

Équipements : Postes des administrateurs (PC-IT1, PC-IT2).

VLAN 20 (Employés) :

Sous-réseau : 10.0.20.0/24 (Passerelle : 10.0.20.1)

Équipements : Postes de la direction (PC-DIR) et de la comptabilité (PC-COMPTA). *Note : Logiquement, le trafic provenant des Agences A (10.0.1.0/24) et B (10.0.2.0/24) est assimilé à cette zone de confiance.*

VLAN 30 (Serveurs internes) :

Sous-réseau : 10.0.30.0/24 (Passerelle : 10.0.30.1)

Équipements : Services critiques (SRV-DNS, SRV-FILES).

VLAN 40 (DMZ) :

Sous-réseau : 10.0.40.0/24 (Passerelle : 10.0.40.1)

Équipements : Serveur public (SRV-WEB). Cette zone démilitarisée protège le LAN en cas de compromission du service exposé.

VLAN 50 (WiFi-Invités) :

Sous-réseau : 10.0.50.0/24 (Passerelle : 10.0.50.1)

Rôle : Réseau totalement isolé destiné aux visiteurs de l'entreprise.

B. Matrice des flux autorisés (Politique de filtrage)

La segmentation par VLAN ne suffit pas si le routeur autorise tous les échanges. Une politique de filtrage rigoureuse basée sur le principe du "Default Deny" (tout bloquer par défaut) a été définie. Voici la matrice des flux autorisés qui dictera la configuration de notre pare-feu :

Depuis le VLAN 10 (Admin) : Accès total autorisé vers toutes les zones (VLANs 20, 30, 40) et Internet pour les besoins d'administration (via SSH/HTTPS). Aucun flux initié par d'autres VLANs vers le VLAN Admin n'est autorisé.

Depuis le VLAN 20 : Accès autorisé vers Internet (HTTP/HTTPS) et accès restreint au VLAN 30 (Serveurs) uniquement sur les ports nécessaires (DNS : UDP/TCP 53, DHCP : UDP 67/68, Partages de fichiers : TCP 445). Accès bloqué vers le VLAN 10, le VLAN 40 (en interne) et le VLAN 50.

Depuis le VLAN 30 (Serveurs) : Ne peuvent répondre qu'aux requêtes entrantes. L'initiation de nouvelles connexions vers le réseau interne est bloquée. Accès restreint vers Internet pour les mises à jour et requêtes DNS récursives.

Depuis Internet vers le VLAN 40 (DMZ) : Seul le flux HTTP/HTTPS (Ports 80/443) est autorisé vers le SRV-WEB.

Depuis le VLAN 40 (DMZ): Tout trafic sortant de la DMZ vers les VLANs internes (10, 20, 30) est strictement bloqué.

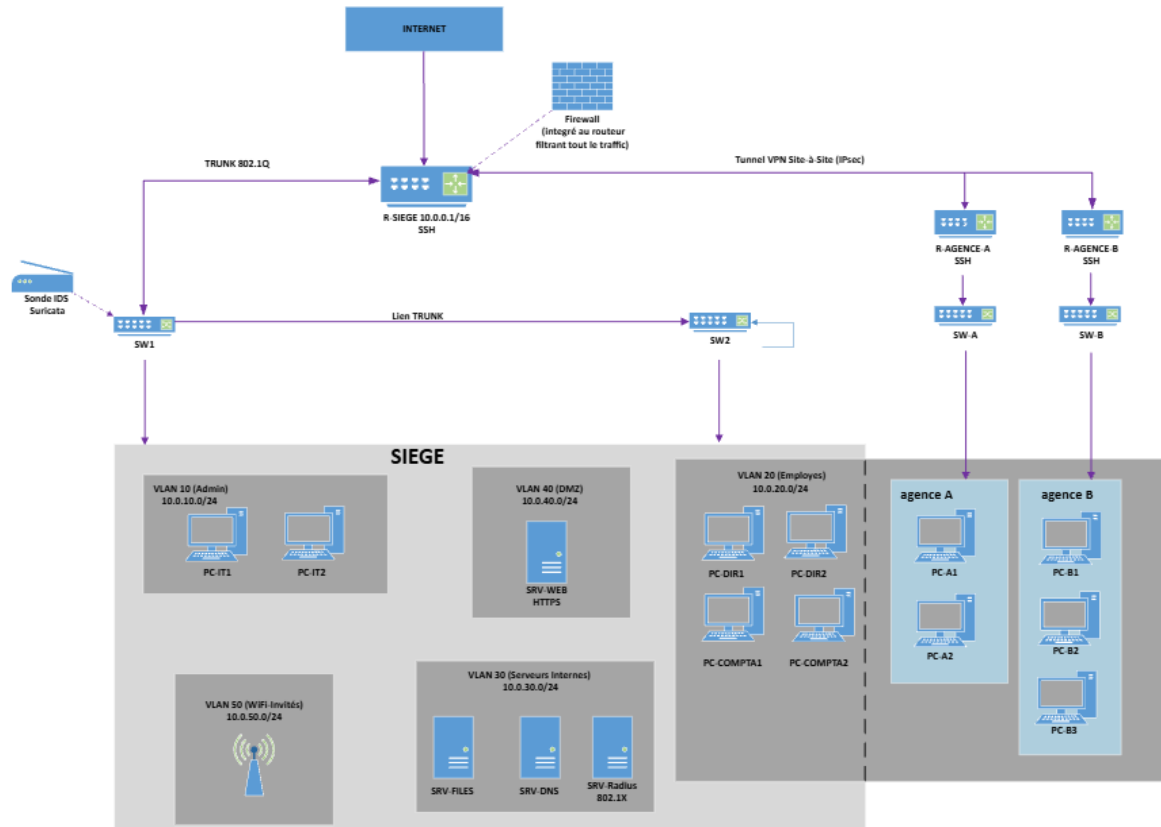
Depuis le VLAN 50 (WiFi-Invités) : Accès exclusif à Internet. Tout trafic vers l'infrastructure interne de NetSecure Corp est bloqué.

2.3 Schéma de l'infrastructure sécurisée

Ce nouveau schéma illustre la topologie cible de NetSecure Corp après la mise en œuvre de notre plan de remédiation. Il met en évidence la disparition du réseau plat initial au profit des 5 VLANs distincts, interconnectés via des liens Trunk (802.1Q) au cœur de réseau.

Le routeur R-SIEGE assume désormais explicitement son double rôle de pare-feu de périmètre et de routeur inter-VLANs. La topologie intègre visuellement nos nouvelles mesures de défense

en profondeur : Le serveur public (SRV-WEB) est isolé dans une DMZ. Une sonde de détection d'intrusion (IDS Suricata) a été positionnée sur un port miroir (SPAN) du switch principal (SW1) pour surveiller les flux internes critiques. Les liaisons inter-sites vers les agences A et B sont encapsulées dans des tunnels VPN IPsec. L'administration est sécurisée de bout en bout par SSH, remplaçant l'ancien protocole Telnet.



3 : Implémentations techniques de sécurité

Cette section détaille les configurations techniques déployées sur l'infrastructure pour répondre aux exigences de la nouvelle architecture et corriger les failles identifiées lors de la Phase 1.

3.1 Sécurisation du périmètre et filtrage (Firewall)

La segmentation logique par VLAN n'est efficace que si elle s'accompagne d'un filtrage strict des communications. L'ancien routeur R-SIEGE, qui routait l'intégralité du trafic sans restriction, a été reconfiguré pour agir comme un véritable pare-feu (Firewall) de couche 3 et 4.

Pour configurer ce filtrage, nous avons utilisé iptables (le pare-feu natif du noyau Linux). Conformément au principe du moindre privilège, nous avons appliqué une politique de sécurité basée sur le **"Default Deny"** (tout bloquer par défaut et n'autoriser que le trafic explicitement nécessaire).

Afin de renforcer la sécurité du périmètre, un script de configuration iptables a été déployé sur le routeur Linux. Ce script applique une politique de filtrage stricte par VLAN, conforme au principe du moindre privilège : chaque zone réseau dispose de règles spécifiques limitant les flux autorisés selon son rôle (Administration, Employés, Serveurs, DMZ, Invités) :

- Configuration des interfaces : chaque interface réseau correspondant aux VLANs
IF_VLAN10="vlan10"
IF_VLAN20="vlan20"
IF_VLAN30="vlan30"
IF_VLAN40="vlan40"
IF_VLAN50="vlan50"
IF_WAN="eth0"
- Réinitialisation des règles : essentiel avant de charger une nouvelle configuration pour éviter les conflits
iptables -F
iptables -X
iptables -t nat -F
iptables -t nat -X
iptables -t mangle -F
iptables -t mangle -X
- Politiques par défaut : tout est bloqué par défaut
iptables -P INPUT DROP
iptables -P OUTPUT DROP
iptables -P FORWARD DROP
- Logging des paquets refusés : création d'une **chaîne personnalisée** pour journaliser les paquets rejetés
iptables -N LOG_DROP
iptables -A LOG_DROP -m limit --limit 5/min -j LOG --log-prefix "FW-DROP: " --log-level 4
iptables -A LOG_DROP -j DROP
- Règles générales : Autorise le trafic local (loopback), indispensable pour le fonctionnement interne du système
iptables -A INPUT -i lo -j ACCEPT
iptables -A OUTPUT -o lo -j ACCEPT
- Autorise les **connexions déjà établies ou liées**
iptables -A INPUT -m state --state ESTABLISHED, RELATED -j ACCEPT
iptables -A OUTPUT -m state --state ESTABLISHED, RELATED -j ACCEPT
iptables -A FORWARD -m state --state ESTABLISHED, RELATED -j ACCEPT

Ce filtrage garantit une isolation stricte entre les VLANs :

- Les administrateurs (VLAN 10) disposent d'un accès complet aux serveurs et à la DMZ.
- Les employés (VLAN 20) accèdent uniquement aux services internes et à Internet via le WAN.
- Les serveurs (VLAN 30) communiquent avec la DMZ pour les bases de données.
- Les invités (VLAN 50) sont confinés à un accès web sortant.
- Les paquets refusés sont journalisés via la chaîne LOG_DROP pour analyse.

3.2 Détection d'intrusion (IDS) avec Suricata

Pour apporter une visibilité sur les flux internes et détecter d'éventuelles attaques ou mouvements latéraux, nous avons déployé la solution open-source Suricata en mode NIDS (Network Intrusion Detection System).

Positionnement et configuration La sonde a été connectée sur un port miroir (SPAN) du switch principal SW1. Cette position stratégique permet d'écouter une copie du trafic transitant vers la zone des serveurs (VLAN 30) et la DMZ (VLAN 40). Dans le fichier de configuration `suricata.yaml`, la variable `HOME_NET` a été définie pour englober nos nouveaux sous-réseaux (les VLANs 10, 20, 30 et 40), tandis que `EXTERNAL_NET` désigne le reste d'Internet.

Règles de détection personnalisées Afin de répondre aux menaces spécifiques identifiées lors de notre audit (Phase 1), nous avons rédigé un jeu de règles personnalisées. L'objectif est de générer des alertes précises dans le fichier `eve.json` en cas de comportement malveillant.

Voici 5 règles critiques déployées sur notre sonde :

1. **Détection d'administration en clair (Telnet)** Puisque Telnet a été banni de notre infrastructure au profit de SSH, toute tentative de connexion sur le port 23 est désormais considérée comme une anomalie critique (tentative de compromission d'équipement).
2. **Détection de scan de ports (Nmap SYN Scan)** Pour détecter la phase de reconnaissance d'un attaquant (similaire au scan Nmap observé dans l'audit), nous ciblons les rafales de paquets TCP contenant uniquement le flag SYN, grâce à l'option de seuil (threshold).
3. **Détection de Rogue DHCP** Pour prévenir les attaques de type DHCP Starvation ou Man-in-the-Middle (via la distribution de mauvaises passerelles), cette règle détecte les réponses DHCP (DORA : Offer/Ack) provenant de machines autres que notre serveur DHCP officiel (SRV-DNS - 10.0.30.10).

4. Détection de trafic Web suspect (DMZ) Cette règle inspecte le trafic HTTP à destination de notre serveur Web public (SRV-WEB en DMZ). Elle recherche des mots-clés spécifiques dans l'URI (comme /admin) pour détecter des tentatives d'accès aux pages d'administration.

5. Détection d'anomalies ARP (Prévention ARP Spoofing) Bien que la protection principale contre l'ARP Spoofing se fasse au niveau de la couche 2 sur les switchs (DAI), l'IDS peut détecter des requêtes ARP anormalement massives, symptomatiques d'un empoisonnement de cache en cours (comme observé avec l'outil *bettercap* lors de la Phase 1).

3.3 Sécurisation des accès physiques et sans-fil

L'audit a révélé que l'accès à l'infrastructure de NetSecure Corp n'était pas suffisamment contrôlé, que ce soit pour l'administration des équipements, l'accès physique aux prises réseau ou les connexions WiFi. Afin de garantir le principe de "Zero Trust", nous avons durci l'ensemble de ces accès.

A. Chiffrement de l'administration (SSH) :

L'usage du protocole Telnet, qui transmettait les identifiants en clair (comme observé dans notre analyse Wireshark), a été définitivement banni de l'ensemble des routeurs et switchs de l'entreprise. Il a été remplacé par le protocole SSH (Secure Shell) sur le port TCP 22. Ainsi, toutes les sessions d'administration sont désormais chiffrées de bout en bout, rendant toute tentative d'écoute inopérante. De plus, les mots de passe par défaut (cisco/cisco) ont été remplacés par des mots de passe robustes.

B. Contrôle d'accès filaire (802.1X)

Auparavant, le simple fait de brancher un équipement sur une prise murale donnait un accès complet au réseau. Pour corriger cette faille, nous avons déployé le standard d'authentification IEEE 802.1X sur tous les ports d'accès des switchs. Désormais, lorsqu'un poste se connecte, le port du switch reste bloqué en état "non autorisé". Le switch relaye les identifiants de l'utilisateur vers notre nouveau serveur d'authentification RADIUS. Ce n'est qu'en cas de succès que le port s'ouvre et que le poste est dynamiquement affecté au VLAN correspondant à son profil.

C. Durcissement de la sécurité WiFi

L'ancien réseau sans-fil reposait sur le standard WPA2-PSK avec une clé pré-partagée faible, ce qui le rendait hautement vulnérable aux attaques par force brute. Conformément aux recommandations de sécurité, nous avons migré l'infrastructure vers le standard WPA2-Enterprise couplé à un serveur RADIUS. Les visiteurs, quant à eux, sont isolés sur le VLAN 50 dédié.

Conclusion

L'audit initial de l'infrastructure de NetSecure Corp a mis en exergue des vulnérabilités critiques liées à une conception obsolète : un réseau "plat" favorisant les mouvements latéraux, une absence totale d'isolation pour les services publics, et l'utilisation de protocoles non sécurisés. Ces failles exposaient l'entreprise à des risques majeurs d'interception de données et de compromission totale.

Grâce à la mise en œuvre de notre plan de remédiation, NetSecure Corp dispose aujourd'hui d'une architecture réseau moderne et résiliente, fondée sur le principe de défense en profondeur. La ségrégation logique par VLANs, couplée au filtrage strict du nouveau routeur pare-feu, isole efficacement les serveurs critiques et la DMZ du trafic utilisateur. En parallèle, le déploiement de la sonde Suricata (IDS) offre désormais une visibilité continue sur les menaces internes, tandis que le contrôle d'accès 802.1X et la migration vers WPA2-Entreprise verrouillent le périmètre d'accès local.

Pour pérenniser ce niveau de sécurité, nous recommandons à NetSecure Corp de maintenir une veille active, de mettre à jour régulièrement les règles de son pare-feu et de son IDS, et de sensibiliser ses collaborateurs aux risques de phishing, l'humain restant souvent le dernier maillon de la chaîne de sécurité.